E-Digit

Digital Compliance per le PMI: semplice, sicura, accessibile.

Sei sicuro che ogni tassello della tua data privacy sia al posto giusto?

I Diritti dei Pazienti e il Consenso

1. Un paziente chiede di cancellare la sua cartella clinica storica invocando il "Diritto all'Oblio". Potete farlo?

NO. I dati di diagnosi e cura vanno conservati per i tempi stabiliti dalla legge sanitaria (spesso a tempo indeterminato).

Molti temono i ricorsi, ma il vero rischio è non sapere cosa si deve conservare e cosa si può cancellare. Con l'audit mappiamo i flussi.

2. Il figlio maggiorenne di un paziente chiede di ritirare i referti del padre senza delega scritta. È consentito?

NO. Il legame di parentela non scavalca la privacy. Serve sempre la delega formale e il documento del delegante.

Questo è l'errore da front-office più comune che genera segnalazioni immediate al Garante.

3. Un paziente revoca il consenso al Fascicolo Sanitario Elettronico (FSE). Potete comunque rifiutarvi di curarlo?

NO. L'erogazione delle cure mediche essenziali non può essere condizionata al consenso per scopi secondari o di condivisione avanzata.

Spiegare la differenza tra consenso alla cura e consenso alla condivisione dei dati è il primo passo di una buona formazione del personale.

4. I dati sanitari di un paziente famoso vengono consultati da un infermiere non in turno per pura curiosità. È reato?

SÌ. È un accesso abusivo a sistema informatico e violazione del segreto d'ufficio/professionale, punibile penalmente.

Il Garante ha sanzionato ASL per decine di migliaia di euro per dipendenti "curiosi". Servono sistemi di tracciamento (log) efficienti.

5. È possibile comunicare l'esito di un esame istologico a un paziente per telefono senza aver verificato la sua identità certa?

NO. I dati sensibili non possono essere comunicati a voce senza procedure di identificazione sicura dell'interlocutore.

Una procedura telefonica non standardizzata è una bomba a orologeria per la struttura.

6. Un centro diagnostico può pubblicare sul proprio sito web una recensione positiva di un paziente includendo il suo nome, cognome e la patologia curata?

SÌ, ma solo con consenso esplicito. Serve un consenso specifico per finalità di marketing/comunicazione, separato da quello medico.

Spesso l'ufficio marketing si muove senza consultare il DPO, creando violazioni visibili a chiunque sul web.

7. Un paziente chiede copia della sua cartella clinica. La struttura può chiedere un pagamento di 500 euro come "tariffa di deterrenza"?

NO. Il GDPR prevede che il diritto di accesso sia gratuito. Si può chiedere solo un rimborso vivo per i costi dei supporti fisici (es. CD o stampe).

Tariffe ingiustificate portano a ricorsi immediati. Digitalizzare il rilascio con MisterCompliance abbatte questi costi vivi.

8. Se un paziente non firma l'informativa privacy, il medico può comunque operarlo in caso di immediato pericolo di vita?

SÌ. In caso di emergenza sanitaria e pericolo di vita (salvaguardia degli interessi vitali), il trattamento dei dati è lecito anche senza consenso.

La privacy non blocca le emergenze, ma il personale deve sapere esattamente quando si applica questa deroga.

9. Una struttura sanitaria può inviare un promemoria SMS per una visita di controllo futura a un paziente senza un consenso specifico?

SÌ. Se rientra nel legittimo interesse per la continuità assistenziale o nel contratto di cura, ma il paziente deve poter fare opt-out facilmente.

Attenzione a non trasformare il promemoria in pubblicità (es. sconti su altri trattamenti), altrimenti scatta l'obbligo di consenso commerciale.

Personale, Autorizzazioni e Formazione

1. Un nuovo infermiere entra in reparto. Può iniziare a usare i software clinici usando l'account del caposala per i primi giorni?

NO. Ogni utente deve avere credenziali strettamente personali per garantire la tracciabilità delle operazioni.

Se c'è un errore medico o una fuga di dati, la condivisione degli account rende impossibile difendersi legalmente.

2. La formazione in materia di protezione dei dati per i dipendenti sanitari è facoltativa o obbligatoria?

OBBLIGATORIA. Il GDPR (Art. 39) richiede espressamente la formazione del personale autorizzato al trattamento dei dati.

Nelle ispezioni della Guardia di Finanza, il registro dei corsi di formazione sulla privacy è la prima cosa che viene controllata.

3. Un medico va in pensione. Il suo account sui sistemi ospedalieri può essere lasciato attivo "per consultazione"?

NO. Gli account dei dipendenti cessati vanno disattivati immediatamente per evitare accessi non autorizzati.

Gli account "fantasma" sono la porta d'ingresso preferita dagli hacker.

4. Gli studenti di medicina (specializzandi o tirocinanti) possono accedere alle cartelle cliniche elettroniche?

SÌ, ma devono essere formalmente designati. Vanno nominati come autorizzati al trattamento e vincolati al segreto.

Spesso ci si dimentica degli stagisti o dei tirocinanti, lasciandoli operare in una zona grigia legale rischiosissima.

5. Se un dipendente smarrisce le proprie credenziali d'accesso, può scriverle su un post-it sotto la tastiera del PC di reparto?

NO. È una palese violazione delle misure minime di sicurezza organizzativa.

La sicurezza è fatta di abitudini. MisterCompliance aiuta a fare audit interni per scovare queste cattive pratiche prima che lo faccia un ispettore.

6. Un coordinatore di reparto può inserire in una chat pubblica i turni di lavoro indicando i motivi di malattia dei singoli dipendenti?

NO. I dati sullo stato di salute dei dipendenti godono di massima tutela e non possono essere diffusi ai colleghi.

La privacy in sanità non riguarda solo i pazienti, ma anche la gestione del personale interno (rischio vertenze sindacali).

7. Chi è il responsabile legale se un dipendente, non formato, diffonde per errore i dati di un paziente?

La struttura sanitaria (il Titolare). La struttura risponde per "culpa in vigilando" o "culpa in educando" se non dimostra di averlo formato.

La responsabilità finale è sempre del Direttore Generale o Amministratore. Proteggere la struttura significa fare formazione vera.

8. Un medico può fotografare una ferita particolare di un paziente con il proprio smartphone privato per motivi di studio personale?

NO. Le immagini cliniche raccolte con strumenti personali non aziendali violano le policy di sicurezza dei dati.

Se il telefono viene smarrito o hackerato, quelle foto diventano un data breach della struttura. Servono dispositivi o canali aziendali protetti.

9. La designazione scritta del personale autorizzato al trattamento dei dati può essere fatta verbalmente?

NO. Deve essere un atto formale scritto (cartaceo o digitale) per soddisfare il principio di "Accountability" (Responsabilizzazione).

Se non è scritto, per il Garante non esiste. Digitalizzare le nomine con un software centralizzato fa risparmiare mesi di lavoro.

Fornitori Esterni e Responsabili

1. La ditta informatica che fa manutenzione da remoto ai server della cartella clinica deve firmare un contratto privacy?

SÌ. Deve essere nominata formalmente "Responsabile Esterno del Trattamento" ai sensi dell'Art. 28 del GDPR.

Molti pensano che basti il contratto commerciale. Senza l'accordo ex Art. 28, la comunicazione di dati alla ditta IT è un illecito amministrativo.

2. Se un fornitore esterno nominato subisce un attacco hacker e perde i dati dei vostri pazienti, la colpa è solo sua?

NO. La struttura sanitaria conserva la responsabilità se non ha vigilato e verificato le misure di sicurezza del fornitore prima di sceglierlo.

Il GDPR vi impone di scegliere solo fornitori che diano garanzie adeguate. Voi come fate lo screening dei vostri fornitori?

3. Il consulente del lavoro esterno che gestisce le buste paga dei medici deve essere nominato Responsabile Esterno del Trattamento?

SÌ. Tratta dati personali (anche sensibili, come trattenute sindacali o certificati medici) per conto della struttura.

Tutti i professionisti esterni che orbitano attorno alla clinica vanno censiti e contrattualizzati lato privacy.

4. Una cooperativa esterna fornisce infermieri per coprire i turni notturni. La cooperativa è un Titolare Autonomo o un Responsabile Esterno?

È un Responsabile Esterno (Art. 28) per le attività di cura che i suoi infermieri svolgono sui dati della vostra struttura.

Definire correttamente i ruoli privacy evita rimpalli di responsabilità spaventosi in caso di contenzioso legale.

5. Le strutture sanitarie devono verificare periodicamente (es. una volta all'anno) che i fornitori esterni rispettino i contratti privacy stipulati?

SÌ. Il GDPR richiede un monitoraggio periodico delle garanzie prestate dai Responsabili del Trattamento.

Mandare un foglio da firmare non basta, serve un sistema di audit periodico dei fornitori. MisterCompliance automatizza questa verifica.

6. Un fornitore software basato fuori dall'Europa (es. USA) può ospitare i dati dei pazienti senza tutele aggiuntive?

NO. Il trasferimento di dati sanitari extra-UE richiede basi legali specifiche (come le Clausole Contrattuali Standard o accordi internazionali validati).

Molti usano cloud americani non conformi senza saperlo. Rischiano sanzioni enormi dal Garante solo per la localizzazione dei dati.

7. La ditta che si occupa della distruzione dei documenti cartacei contenenti dati sanitari deve essere nominata ex Art. 28?

SÌ. Anche la distruzione e lo smaltimento dei dati costituiscono a tutti gli effetti un trattamento di dati personali.

Se i faldoni finiscono in una discarica comune perché la ditta non era qualificata, la sanzione ricade interamente sulla struttura.

8. Un Responsabile Esterno (fornitore) può nominare un sub-fornitore senza l'autorizzazione scritta della struttura sanitaria?

NO. Il GDPR vieta l'affidamento a sub-responsabili senza una preventiva autorizzazione (specifica o generale) del Titolare del trattamento.

Dovete avere il controllo della filiera informatica per sapere esattamente dove finiscono i dati sensibili dei vostri reparti.

9. Se cambiate il software di gestione della radiologia, il vecchio fornitore può tenersi una copia del database dei pazienti "per sicurezza"?

NO. Alla fine del contratto, il fornitore deve restituire o distruggere tutti i dati personali, salvo obblighi di legge specifici.

Verificare la cancellazione dei dati alla chiusura dei rapporti contrattuali è un'attività critica di compliance informatica.

Sicurezza Informatica e Misure Tecniche

1. Il GDPR definisce una lunghezza minima universale per le password (es. 8 caratteri)?

NO. Il GDPR non dà numeri fissi, ma richiede misure "adeguate al rischio corrente" (oggi si preferiscono password lunghe o sistemi MFA).

Non basta più la vecchia legge del 2003. Oggi serve una valutazione del rischio reale fatta con strumenti evoluti per capire se l'infrastruttura regge.

2. L'autenticazione a due fattori (MFA) è raccomandata per l'accesso ai sistemi sanitari da remoto (es. Smart Working)?

SÌ, è considerata una misura indispensabile dalle linee guida del Garante per l'accesso ai dati sanitari via web.

Se permettete ai medici di vedere le cartelle da casa con una semplice password, siete esposti a un rischio altissimo di intrusione.

3. Se fate il backup dei dati della clinica su un hard disk esterno che il direttore si porta a casa in borsa ogni sera, siete protetti?

NO. Se l'hard disk non è cifrato e viene rubato o perso, si trasforma in un data breach grave di dati in chiaro.

I backup fisici non protetti sono un rischio enorme. Serve una strategia di disaster recovery professionale e cifrata.

4. I medici possono scambiarsi i referti o le foto cliniche dei casi complessi usando i propri gruppi WhatsApp privati?

NO. I canali di messaggistica consumer non garantiscono la tracciabilità aziendale, la sicurezza e la conformità al GDPR per dati sanitari.

Sappiamo che i medici lo fanno per fare prima, ma espongono la struttura. Bisogna fornire loro strumenti aziendali alternativi e sicuri.

5. I PC posizionati nei corridoi degli ambulatori possono essere lasciati senza blocco schermo automatico quando il medico si allontana?

NO. Chiunque (pazienti, visitatori) potrebbe leggere o modificare i dati a schermo. Il blocco automatico deve essere impostato a pochi minuti.

Un controllo visivo di un corridoio è una misura fisica elementare che spesso salta per pura fretta.

6. L'uso di una rete Wi-Fi pubblica e senza password all'interno dell'ospedale per far connettere i tablet dei medici ai server interni è sicuro?

NO. I dati clinici intercettati su reti Wi-Fi aperte sono facilmente leggibili. I tablet devono viaggiare su reti Wi-Fi aziendali dedicate e separate da quelle degli ospiti.

Separare la rete "ospiti" dalla rete "sanitaria" è l'ABC della sicurezza IT in ospedale.

7. Che cos'è la "Cifratura" (o crittografia) dei dati sanitari?

Una misura tecnica che rende i dati del database totalmente illeggibili a chiunque non possieda la chiave di decifrazione segreta.

Se i server vengono violati ma i dati sono cifrati, l'impatto per i pazienti è quasi nullo e spesso si evita la sanzione del Garante.

8. I log di accesso (chi ha aperto quale cartella clinica e quando) devono essere conservati in modo inalterabile?

SÌ. Le linee guida del Garante per i dossier sanitari impongono la tracciabilità inalterabile degli accessi dei medici.

Senza log sicuri, non potete sapere se c'è stata un'infrazione interna o un furto di dati. MisterCompliance mappa questi requisiti tecnici.

9. Un vecchio computer contenente storici di cartelle cliniche viene regalato a una scuola. Basta fare un semplice "Cancella" sui file prima di consegnarlo?

NO. I file cancellati sono facilmente recuperabili. Serve una formale procedura di "cancellazione sicura" (wiping) o la distruzione fisica dell'hard disk.

Il "fai da te" informatico in sanità causa fughe di dati imbarazzanti e sanzioni pesanti.

Whistleblowing e Segnalazioni

1. Per raccogliere le segnalazioni di Whistleblowing basta attivare una normale casella email aziendale (es. whistleblowing@clinica.it)?

NO. La legge impone l'uso di canali specifici, separati e crittografati che garantiscano l'anonimato assoluto del segnalante (non tracciando l'IP).

L'ANAC applica sanzioni fino a 50.000 euro per canali non a norma. Non si scherza più dal 2023.

2. La normativa sul Whistleblowing si applica anche alle strutture sanitarie private?

SÌ. Si applica a tutte le aziende (incluse le sanitarie private) che hanno impiegato la media di almeno 50 lavoratori nell'ultimo anno.

Molte cliniche private pensano sia un obbligo solo del pubblico. Se superano i 50 dipendenti/collaboratori, rischiano grosso se non sono adeguate.

3. Se un medico segnala un illecito interno tramite Whistleblowing, la direzione può sospenderlo in via cautelare per motivi disciplinari?

NO. La legge vieta severamente qualsiasi forma di ritorsione (diretta o indiretta) contro il segnalante. La sospensione sarebbe nulla.

Gestire le segnalazioni richiede un protocollo rigido. Il nostro tool permette di gestire il flusso escludendo conflitti di interesse aziendali.

4. Chi è l'organo che applica le sanzioni in Italia se la struttura non attiva il canale di Whistleblowing?

L'ANAC (Autorità Nazionale Anticorruzione), che collabora attivamente con la Guardia di Finanza.

Oltre al Garante Privacy per i dati, sui canali di segnalazione c'è anche lo spettro delle sanzioni ANAC. Due fronti da presidiare.

5. Le segnalazioni di Whistleblowing possono essere gestite direttamente dall'Amministratore Delegato della clinica?

SCONSIGLIATO / NO. La gestione deve essere affidata a una persona o ufficio interno autonomo e dedicato, oppure a un soggetto esterno indipendente.

Se il segnalante accusa il vertice, c'è un conflitto d'interessi insanabile. Serve una piattaforma terza per garantire la terzietà del processo.

6. Un fornitore esterno o un medico libero professionista che collabora con l'ospedale può usare il canale di Whistleblowing aziendale?

SÌ. La tutela del Whistleblowing si estende non solo ai dipendenti subordinati, ma anche a consulenti, fornitori, tirocinanti e azionisti.

Il perimetro degli utenti che possono fare segnalazioni è vastissimo. Il canale deve essere accessibile in modo sicuro anche dall'esterno della rete aziendale.

7. Entro quanti giorni la struttura deve dare un riscontro al segnalante sull'esito della sua segnalazione?

Entro 3 mesi dalla data dell'avviso di ricevimento della segnalazione.

Ci sono scadenze temporali perentorie. Se non avete un software di tracciamento dei ticket, perdersi le date è facilissimo.

8. La piattaforma informatica utilizzata per il Whistleblowing deve rispettare il GDPR?

SÌ, assolutamente. Tratta dati altamente riservati. Deve applicare la crittografia dei dati e limitare l'accesso solo al gestore della segnalazione.

Whistleblowing e Privacy si incrociano perfettamente. È un unico grande ecosistema di compliance aziendale.

9. Se la segnalazione si rivela infondata, il segnalante viene sempre punito o licenziato?

NO. La tutela si applica se il segnalante aveva ragionevoli motivi di ritenere le informazioni vere al momento della segnalazione. Punita è solo la calunnia intenzionale.

Creare un clima di fiducia e trasparenza evita che le problematiche esplodano all'esterno (es. stampa o procure).

Data Breach e Gestione Incidenti

1. Un ransomware blocca l'accesso alle cartelle cliniche per 48 ore ma non risulta che i dati siano stati rubati o diffusi. È un Data Breach?

SÌ. Il data breach comprende anche la perdita accidentale della "disponibilità" dei dati personali, non solo il furto.

Se i medici non accedono alle cartelle e si bloccano le sale operatorie, il rischio per i pazienti è critico. Va notificato al Garante.

2. In caso di Data Breach che comporta rischi per i pazienti, entro quante ore bisogna notificare l'evento al Garante della Privacy?

Entro 72 ore dal momento in cui la struttura ne viene a conoscenza.

72 ore sono pochissime, soprattutto se l'attacco capita il venerdì sera. Se non avete una procedura rapida pronta, siete fuori tempo massimo e scatta la sanzione.

3. Se un dipendente invia per errore via email il referto di un paziente a un omonimo (paziente sbagliato), si tratta di un Data Breach?

SÌ. È una divulgazione non autorizzata di dati sanitari sensibili a un terzo non avente diritto.

Capita spessissimo per distrazione. Va registrato internamente nell'apposito registro dei data breach e valutata l'entità del danno.

4. Tutti i data breach subiti da una struttura sanitaria devono essere notificati al Garante della Privacy?

NO. Vanno notificati solo quelli che presentano un rischio per i diritti e le libertà delle persone. Tutti, però, vanno iscritti nel registro interno.

Chi decide se il rischio è "basso", "medio" o "alto"? Serve una metodologia di calcolo formale, integrata nei nostri sistemi di audit.

5. Se subite un furto di faldoni cartacei storici dall'archivio scantinato dell'ospedale, dovete preoccuparvi lato privacy?

SÌ. Il GDPR protegge i dati personali indipendentemente dal supporto (digitale o cartaceo). È un data breach a tutti gli effetti.

Spesso si pensa che la privacy sia solo informatica. Gli archivi fisici abbandonati sono tra le sanzioni preferite dagli ispettori.

6. Se un attacco hacker diffonde online le cartelle cliniche dei vostri pazienti, oltre al Garante dovete informare anche i singoli pazienti interessati?

SÌ. Se il data breach presenta un rischio "elevato" per i pazienti (es. furto d'identità, discriminazione, danno reputazionale), vanno informati tempestivamente tutti i diretti interessati.

Il danno d'immagine per la clinica in questo caso è devastante. Prevenire con audit continui serve a proteggere il brand della struttura.

7. Chi firma e invia formalmente la notifica di Data Breach all'Autorità Garante?

Il Titolare del Trattamento (Direttore Generale/Legale Rappresentante), solitamente coadiuvato dal Data Protection Officer (DPO).

Il peso legale ricade sui dirigenti. Date ai vostri vertici gli strumenti per decidere con dati certi in mano.

8. La tenuta del "Registro dei Data Breach" (registro degli incidenti) è facoltativa per un ospedale?

NO, è obbligatoria. Qualsiasi incidente, anche minimo e non notificato al Garante, deve essere catalogato internamente con le relative azioni correttive prese.

La Guardia di Finanza chiede subito il Registro Incidenti. Se è vuoto in una struttura complessa, solleva forti sospetti di omessa gestione.

9. Pagare il riscatto in criptovalute agli hacker per sbloccare i server sanitari cancella l'obbligo di notificare il Data Breach?

NO. Il pagamento non dà garanzie sulla distruzione dei dati da parte dei criminali e non sana in alcun modo l'illecito amministrativo della mancata sicurezza.

Pagare alimenta il crimine e non risolve la compliance. La vera soluzione è la resilienza dell'infrastruttura e la governance dei dati con strumenti dedicati.